Securing AI in Medical Imaging

IT595 Master's Capstone in Cybersecurity Management

Presented by

Danielle Hendon

Content

Presented by
Danielle Hendon

Project Purpose and Scope

This project will conduct a cybersecurity-focused assessment of AI-enabled medical imaging systems used in healthcare organizations to examine the challenges and vulnerabilities across the imaging AI data lifecycle. The project seeks to develop a tailored security and governance framework that ensures the confidentiality, integrity, and availability of patient imaging data while supporting ethical, secure, and effective adoption of AI technologies in healthcare imaging environments.

The scope includes imaging modalities such as Nuclear Medicine, X-ray, CT, MRI, and ultrasound that rely on AI for image analysis, triage, or diagnostic assistance. In turn, this helps doctors manage their workloads and improve health outcomes (*Integrating AI Into Clinical Workflows for Medical Imaging*, 2024).

Lessons Learned

1.

Cascading Risks

Example:
Physician over dependance → laziness → skill depletion → useless without AI tool.

2.

Adjust Timelines

Need to switch milestone completion time frames during project execution.

3.

Reference Research

Continuously reference previously researched material to form a well rounded project.

4.

Multi-layered Approach

Implementing disclaimers, consent forms, and policies.

Introduction

Horizon Valley Health System (HVHS) is a fictional integrated healthcare organization used for the purposes of this capstone project. HVHS operates a network of regional hospitals, outpatient clinics, and diagnostic imaging centers that serve a diverse patient population across multiple communities. The organization provides comprehensive medical services, including advanced radiology and nuclear medicine imaging such as CT, MRI, PET, ultrasound, and X-ray. As part of its commitment to improving diagnostic accuracy, operational efficiency, and patient outcomes, HVHS has begun integrating artificial intelligence (AI) technologies into its medical imaging workflows to assist clinicians with image analysis and clinical decision support. Because these systems rely on large volumes of sensitive medical imaging data and associated patient information, HVHS must implement strong cybersecurity, data governance, and privacy safeguards to protect protected health information (PHI), ensure responsible AI use, and maintain patient trust. This capstone project examines potential cybersecurity risks associated with AI-enabled medical imaging systems at Horizon Valley Health System and proposes governance policies and technical controls to mitigate those risks while supporting safe and effective AI adoption in healthcare.

Best Practices

Industry

- FIPPs (Fair Information Practice Principles)

Includes awareness, consent, and access (Tegomoh 2025)

- Privacy by design

data and privacy protections should be embedded in the design and lifecycle of an AI system (Cavoukian & Information and Privacy Commissioner of Ontario, 2009/2011)

- Zero Trust

Professional

- Data minimization

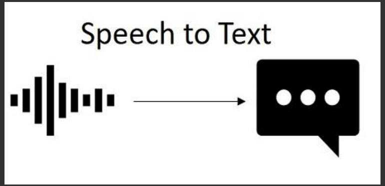
data collection should be limited to what is necessary to carry out the task and that data should also be deleted when no longer needed (Tegomoh 2025)

- Encryption
- Default privacy settings

Uses of AI in Medical Imaging

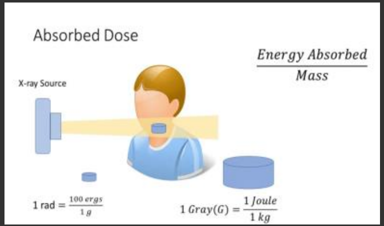
Report Generation

Speech to Text



Dose Measurement

Radiation doses calculated based on patient height and weight



Anomaly Detection

Faster, more accurate detections

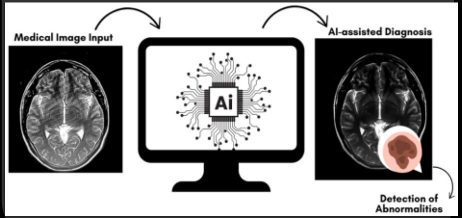
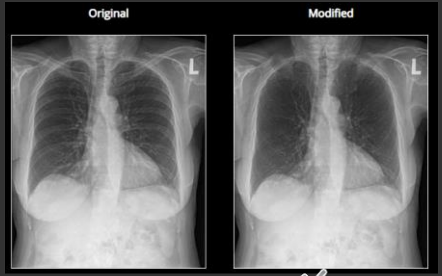


Image Enhancement

Sharper, clearer images

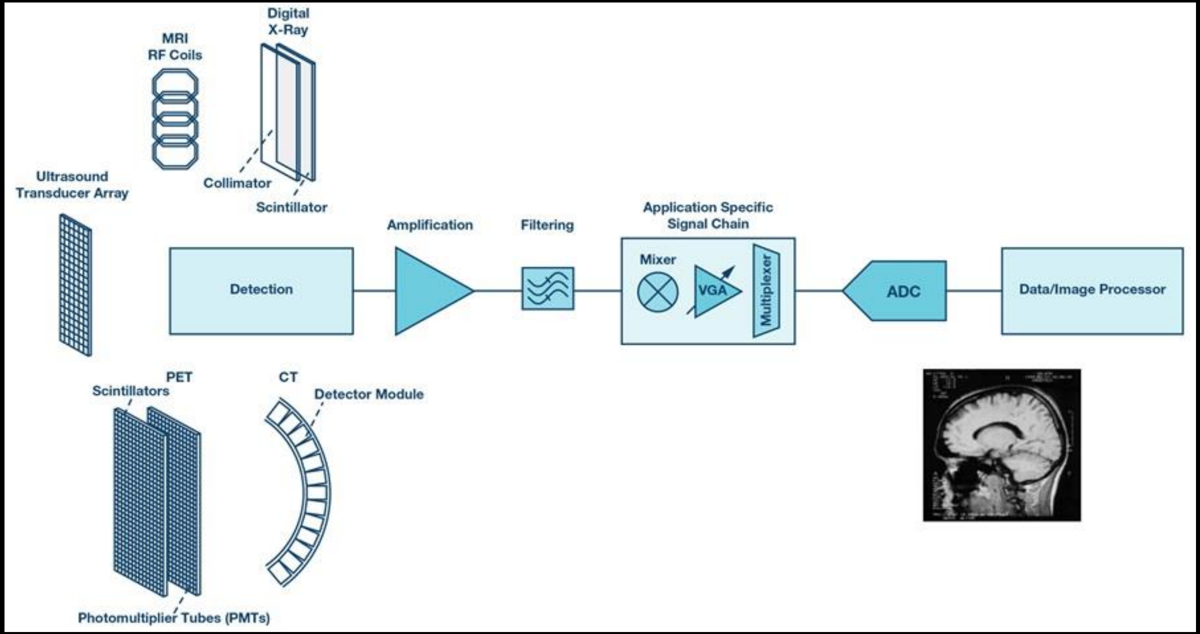


carestream.com

Medical Imaging Acquisition

Image processing from collection to image formation.

- Detector (X-Ray, CT, MRI)

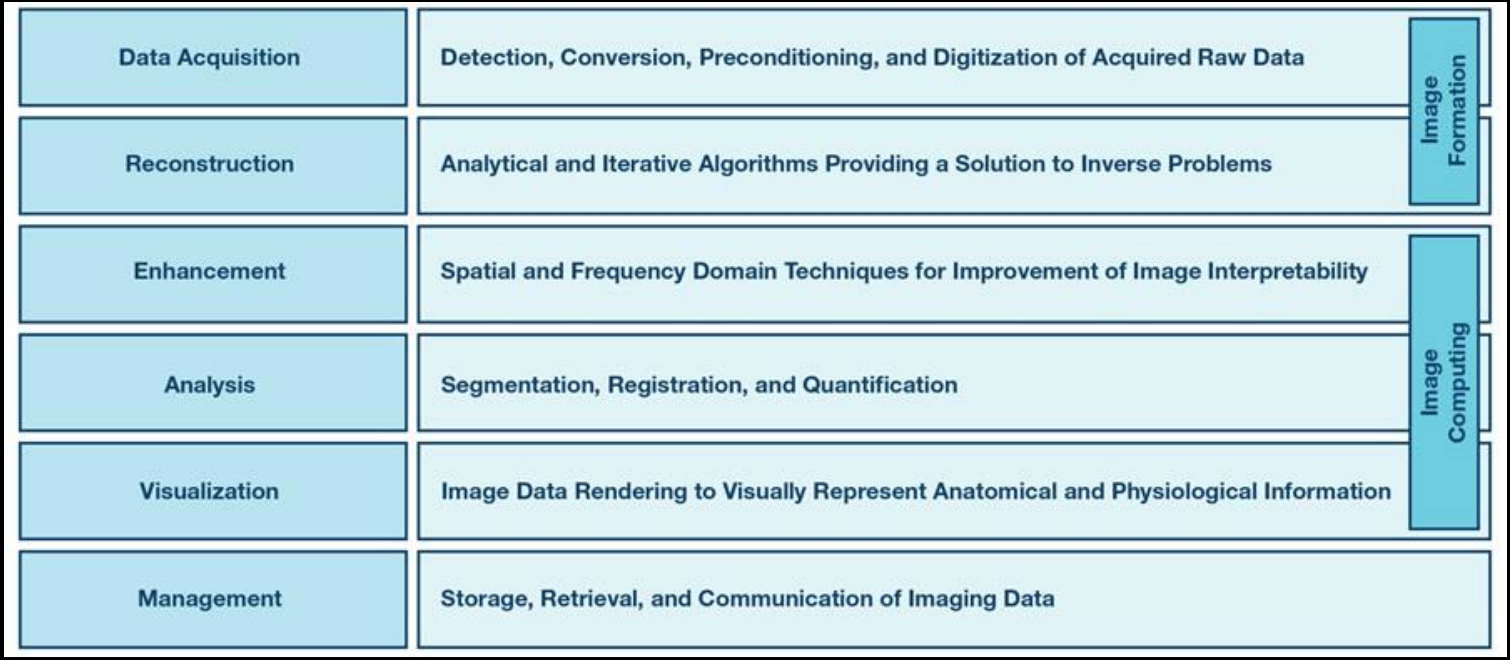


(Patyuchenko, 2019b)

Medical Imaging Data Lifecycle

Image processing from collection to image interpretation.

- Image acquisition (image formation)
- AI and technologist analysis (computing)
- Storage of clinical decision support



(Patyuchenko, 2019)

Data Lifecycle Vulnerabilities

Image processing from collection to image interpretation.

- Image acquisition (image formation)
- AI and technologist analysis (computing)
- Storage of clinical decision support

- Poor data segmentation
- Biases data output
- Excessive access
- Insufficient human oversight
- Third-party vulnerabilities

Threats to Patient Data

1. **External Hackers**
2. **Inaccurate Outcomes**
3. **Insider Threats**
4. **Over-Reliance**
5. **Third-Party Vendor**

Cavoukian, A. & Information and Privacy Commissioner of Ontario. (2011)

(Chustecki, 2024)

(Chustecki, 2024)

Defending Patient Data

1. **Encryption, Data segmentation**
2. **Diverse datasets, Explainable results**
3. **Role-based access, Monitoring, Mandatory training**
4. **Human-in-the-loop**
5. **Risk assessments, Agreements**

(Chu et al., 2020)

Ethical Considerations

AI models will need to be trained on real patient data.

- Implement transparency with patients
- Implement diverse training datasets
- De-identify patient data

Frameworks Applicable to Healthcare AI Usage

NIST

- Cybersecurity framework
- AI risk management framework
- SP 800-53

HIPAA

- General data protection
- Business associate agreements
- GDPR (European Union)

(Alder, 2026)

NIST Explained

Cybersecurity Framework

(CSF)

Applicable in medical imaging because of the use of computers to transfer sensitive data.

NIST SP 800-53

Controls

Security and Privacy Controls for Information Systems and Organizations

AI Risk Management

(AI RMF)

Intended to be flexible and to augment existing risk practices which should align with applicable laws, regulations, and norms

HIPAA Explained

HIPAA

Regulation

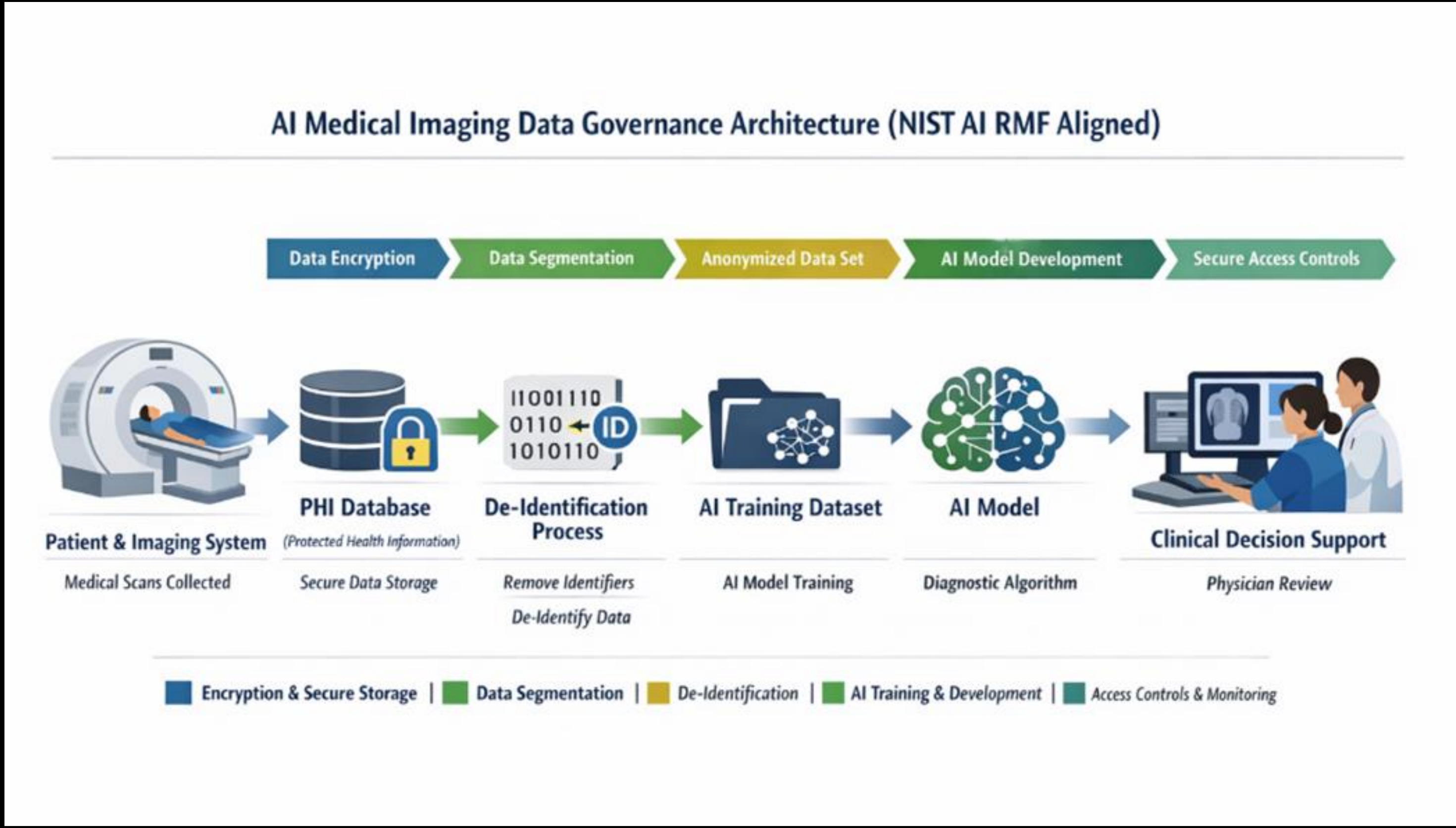
U.S. federal law that protects sensitive patient health information

HIPAA Business Associate

Contract

a contract between a HIPAA covered entity and a business or individual

NIST AI RMF



AI Medical Imaging Data Governance Architecture (NIST AI RMF Aligned)
Data Encryption
Data Segmentation
Anonymized Data Set
AI Model Development
Secure Access Controls
11001110
0110
1010110
ID
Patient & Imaging System
Medical Scans Collected
PHI Database
(Protected Health Information)
Secure Data Storage
De-Identification Process
Remove Identifiers
De-Identify Data
AI Training Dataset
AI Model Training
AI Model
Diagnostic Algorithm
Clinical Decision Support
Physician Review
Encryption & Secure Storage | Data Segmentation | De-Identification | AI Training & Development | Access Controls & Monitoring

Comprehensive Oversight

- Pre-deployment evaluations
- Ongoing monitoring
- Outline current AI risk landscape

User Training

Clinicians and Staff

- Address trust challenges
- Address use of diverse datasets
- Ongoing for nuances and medical diagnoses complexity

Nuances in Medical Diagnostics

- Implement evaluation metrics
- Implement explainable AI
- Ongoing for nuances and medical diagnoses complexity

Transparency

Clinicians and Staff

- The role AI will play in our organization
- AI's benefits to our organization
- AI's limitations or risks to our organization
- Ensures effective and ethical use

Technical Safeguards

Clinicians and Staff

- Implemented throughout data lifecycle
- Data at rest encryption
- Access controls for viewing and editing data
- Continuous monitoring of output
- Quality control of AI tool

Benefits of AI in Medical Imaging

1 **Enhanced**

Medical imaging data protection

2 **Reduced**

Unauthorized access,

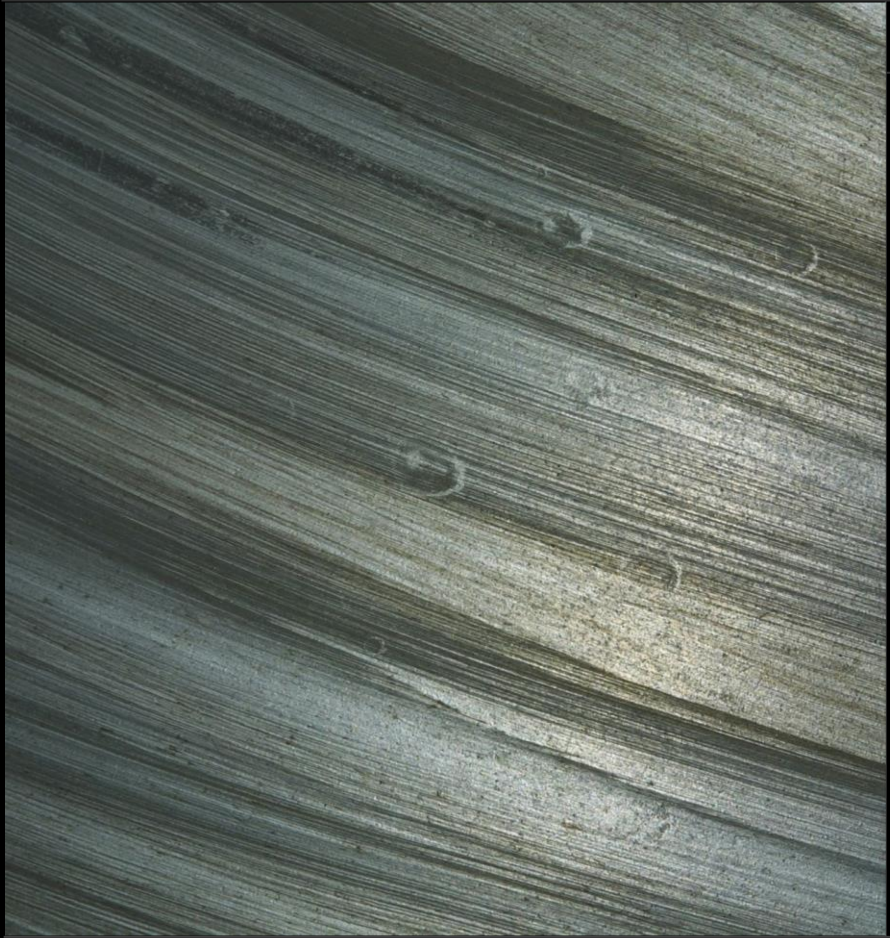
Data leakage,

Model manipulation

3 **Improved**

Alignment with healthcare

privacy standards



Risks of AI in Medical Imaging

- Poor data separation
- Biased data output
- Excessive data access
- Insufficient human oversight
- Third-party vulnerabilities

Risks 1-3 Deep Dive

Poor Data Separation

- External hackers causing data leaks, misuse, ransom attacks
- Can have severe impact
- Mitigate with encryption
- Separate PHI from AI training datasets

Biased Data Output

- Severe impact on organization that can erode patient trust
- Mitigate with diverse training datasets
- Incorporate explainable AI output
- Use AI output disclaimer

Excessive Data Access

- Can lead to insider threat
- Will have significant impact on our organization
- Mitigate with role-based access, account monitoring, mandatory employee training

Risk Assessment Matrix

Severity →

Likelihood ↑	Negligible	Minor	Moderate	Significant	Severe
Very Likely	Low Med	Medium	Med Hi	High	High
Likely	Low	Low Med	Medium	Med Hi	High
Possible	Low	Low Med	Medium	Med Hi	Med Hi
Unlikely	Low	Low Med	Low Med	Medium	Med Hi
Very Unlikely	Low	Low	Low Med	Medium	Medium

Risks 4 and 5

Deep Dive

Insufficient Human Oversight

- Leads to over-reliance on AI output.
- Mitigate by building human-in-the-loop validation and oversight.
- Incorporate AI output disclaimer

Third-Party Vendors

- Various vulnerabilities
- Not controlled by our organization
- Mitigate with HIPAA Business Associate Agreement

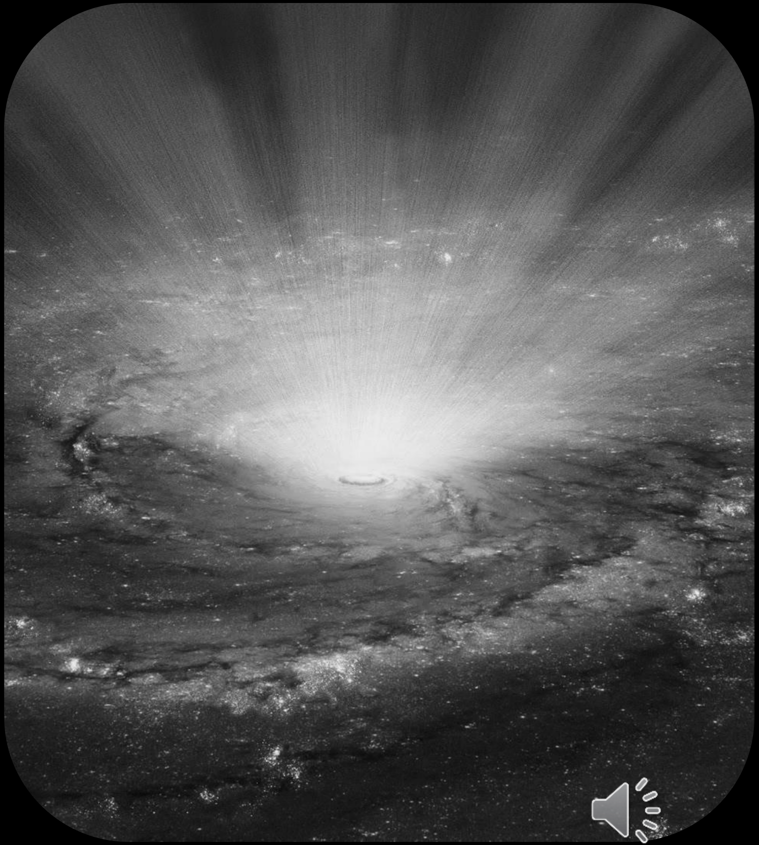
(Alder, 2026)

Risk Matrix

Risk ID	Threat	Vulnerability	Likelihood	Impact	Risk Rating	Mitigation	Stakeholder	Framework
001	External hackers targeting healthcare AI systems	Poor data segmentation	High	Severe	High	Encryption, segment PHI and AI training data	Patients, Healthcare IT and cybersecurity teams	NIST Risk Management Framework, AI RMF
002	Discriminatory or inaccurate outcomes	Biased data	Possible	Severe	Medium - High	explainable AI methods, diverse datasets	Patients, Healthcare IT and cybersecurity teams	AI RMF
003	Insider threats	Excessive access	Possible	Significant	Medium high	Role-based access, monitoring, mandatory training	Patients, Radiologists and Technologists	NIST SP 800-53 Access Control
004	Radiologist over-reliance on AI output	Insufficient human oversight	Very likely	Moderate	Medium - High	Human-in-the-loop validation and oversight	Patients, Radiologists and Technologists	AI RMF
005	Compromised third-party AI vendor	Various vendor vulnerabilities	Likely	Severe	High	Third-party risk assessments, HIPAA Business Associate Agreement	Medical imaging AI vendors	HIPAA Business Associate Agreement

Let’s work together

Our Stakeholders



- Patients and their families
- Radiologist and Technologists
- IT and Cybersecurity teams
- Third-party vendors

External Hackers

1

Targeting healthcare related AI systems and programs

2

Causing data theft, ransom, and misuse

3

Affecting:

- Patients

4

Will need:

- Notice of data collection
- Consent to collect data

Recommendation 2

Biased Output

1

Inaccurate or discriminatory AI output

2

Causing mistrust in our organization

3

Affecting:

- Patients

4

Will need:

- Disclaimer that output can have errors

page 10

Insider Threats

1

Excessive employee access or ill monitored access controls

2

Causing data leakage

3

Affecting:

- Staff with system access

4

Will need:

- Role-based access
- Account monitoring
- Mandatory training

Recommendation 4

Insufficient Oversight

1

Over-reliance on AI output

2

Causing laziness, errors, misdiagnoses

3

Affecting:

- Radiologist and Technologist

4

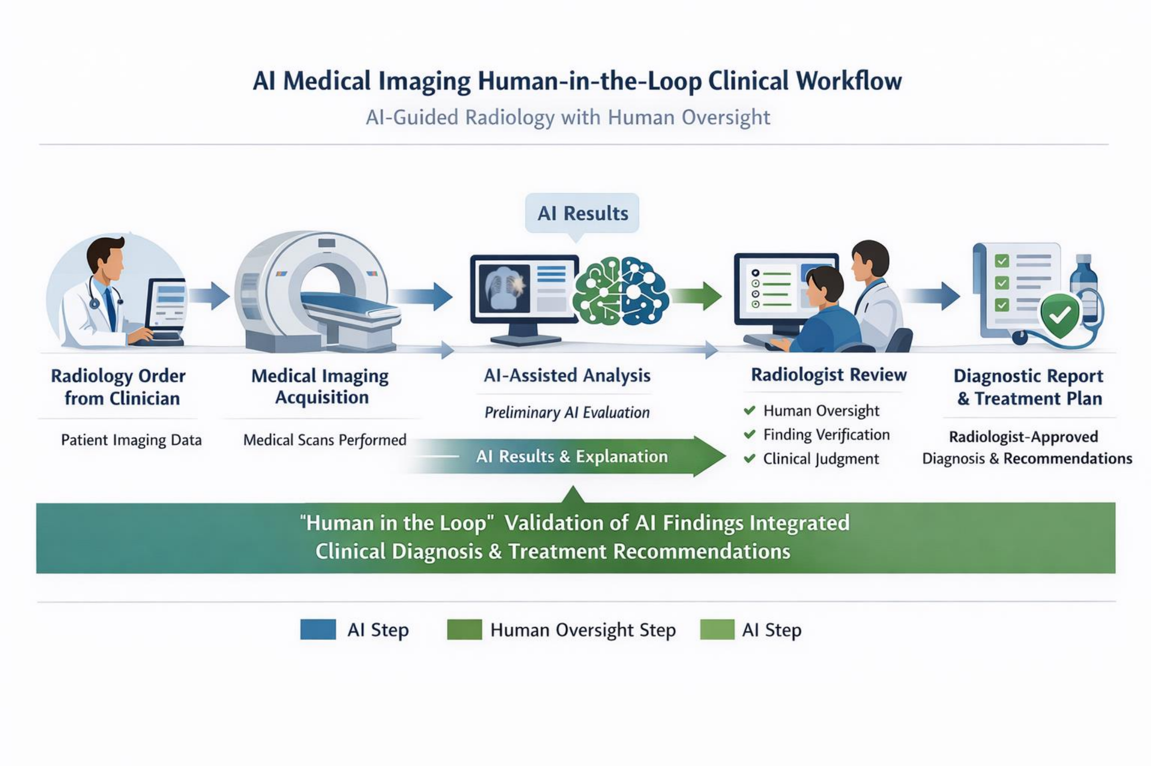
Will need:

- Employee training
- Human-in-the-loop validation

page 17

Recommendation 4

Insufficient Oversight cont.



Third-party Vendors

1

Third-party vendor vulnerabilities

2

Causing various effects on patient data

3

Affecting:

- Third-party vendors

4

Will need:

- HIPAA Business Associate Agreement

Recommendation 6

Policies

Clinicians and Staff

- **Policy 1:** Role-Based Access Control (RBAC)
- **Policy 2:** Account Usage Monitoring
- **Policy 3:** Employee Training for Credential Security
- **Policy 4:** **D**iverse Dataset Collection for AI Model Training
- **Policy 5:** Explainable AI Output
- **Policy 6:** Data Segmentation Between PHI and AI Training Data
- **Policy 7:** Encryption of Medical Imaging Data

Policy Governance and Review

These policies will be reviewed annually or when significant technological or regulatory changes occur.

Oversight is provided by:

- Chief Information Security Officer (CISO)
- IT Governance Committee
- Privacy and Compliance Office

Conclusion

The proposed cybersecurity and governance framework for Horizon Valley Health System provides an effective and ethical approach to securing patient data within AI-enabled medical imaging systems. By implementing technical safeguards such as encryption of imaging data, segmentation between protected health information (PHI) and AI training datasets, and continuous account monitoring, the organization significantly reduces the risk of external cyberattacks and insider threats. In addition, role-based access controls and mandatory employee training strengthen organizational security by ensuring that only authorized personnel can access sensitive patient information and that employees understand their responsibility to safeguard credentials and system access. These controls create multiple layers of protection that work together to reduce vulnerabilities while maintaining operational efficiency within clinical imaging workflows.

The framework also addresses ethical considerations associated with artificial intelligence in healthcare. Policies requiring diverse datasets for AI model training and the implementation of explainable AI outputs help reduce algorithmic bias and increase transparency in AI-assisted diagnostics. Furthermore, training radiologists and technologists to maintain human oversight ensures that AI tools are used as decision-support technologies rather than replacements for professional medical judgment. This human-in-the-loop approach protects patient safety while preserving clinical accountability. By informing both patients and employees about the limitations and appropriate use of AI technologies, the organization promotes transparency, trust, and responsible innovation.

Overall, the proposed solution aligns with recognized cybersecurity and AI governance standards such as the NIST Cybersecurity Framework and the NIST AI Risk Management Framework. By combining strong technical safeguards, clear organizational policies, employee training, and ethical AI oversight, Horizon Valley Health System can responsibly adopt AI-driven medical imaging technologies while protecting patient privacy, maintaining regulatory compliance, and ensuring that technological innovation continues to support high-quality patient care.

References

Alder, S. (2026). *What Is A HIPAA Business Associate Agreement?* hipaajournal.com. https://www.hipaajournal.com/hipaa-business-associate-agreement/

Bone suppression. (n.d.). https://www.carestream.com/en/us/medical/software/eclipse/bone-suppression

Cavoukian, A. & Information and Privacy Commissioner of Ontario. (2011). *Privacy by design*. Information and Privacy Commissioner of Ontario. https://www.sfu.ca/~palys/Cavoukian-2011-PrivacyByDesign-7FoundationalPrinciples.pdf (Original work published 2009)

Chu, L. C., Anandkumar, A., Shin, H. C., & Fishman, E. K. (2020). *The Potential Dangers of Artificial Intelligence for Radiology and Radiologists.* Journal of the American College of Radiology *: JACR*, *17*(10), 1309–1311. https://doi.org/10.1016/j.jacr.2020.04.010

Chustecki M. (2024). *Benefits and Risks of AI in Healthcare: Narrative Review*. Interactive journal of medical research, *13*, e53616. https://doi.org/10.2196/53616

Computer Security Division, Information Technology Laboratory, National Institute of Standards and Technology, U.S. Department of Commerce. (n.d.-a). *Access CPRT - Cybersecurity and Privacy Reference Tool | CSRC | CSRC*. https://csrc.nist.gov/projects/cprt/catalog#/cprt/framework/version/SP_800_53_5_2_0/home?element=AC-06

References

Computer Security Division, Information Technology Laboratory, National Institute of Standards and Technology, U.S. Department of Commerce. (n.d.-b). *Access CPRT - Cybersecurity and Privacy Reference Tool | CSRC | CSRC*. https://csrc.nist.gov/projects/cprt/catalog#/cprt/framework/version/SP_800_53_5_2_0/home

HIPAA for professionals. (n.d.). Health and Human Services.gov. https://www.hhs.gov/hipaa/for-professionals/index.html

Integrating AI into clinical workflows for medical imaging. (2024, April 4). HiE. https://healthcare-in-europe.com/en/news/monai-deploy-siemens-nvidia-medical-imaging.html

Martinez, N., Binkley, C., & Weckman, A. (2025, September 3). *AI governance: maximizing benefit and minimizing harm for patients, providers, and health systems.* Institute for Healthcare Improvement. https://www.ihi.org/library/blog/ai-governance-maximizing-benefit-and-minimizing-harm-patients-providers-and-health

Martinez, N., Moran, B., & Weckman, A. (2025, September 25). *Transparency and training: Keys to trusted AI in healthcare*. Institute for Healthcare Improvement. https://www.ihi.org/library/blog/transparency-and-training-keys-trusted-ai-health-care

National Institute of Standards and Technology. (2018). *Framework for improving Critical Infrastructure Cybersecurity*. National Institute of Standards and Technology. https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf

References

Norori, N., Hu, Q., Aellen, F. M., Faraci, F. D., & Tzovara, A. (2021). *Addressing bias in big data and AI for health care: A call for open science.* Patterns (New York, N.Y.), *2*(10), 100347. https://doi.org/10.1016/j.patter.2021.100347

Patyuchenko, A. (2019, January 19). *Figure 1. Structural classification of the topic categories in medical image processing*. analog.com. https://www.analog.com/en/resources/technical-articles/medical-image-processing-from-formation-to-interpretation.html

Patyuchenko, A. (2019b, March 19). *Figure 2. Generic block diagram of the data acquisition process*. analog.com. https://www.analog.com/en/resources/technical-articles/medical-image-processing-from-formation-to-interpretation.html

Raimondo, G. M., U.S. Department of Commerce, National Institute of Standards and Technology, & Locascio, L. E. (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0). NIST.*gov. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.AI.100-1

Tegomoh, B. (2025). *The Physician AI handbook: Peer-reviewed evidence for every specialty.* https://doi.org/10.5281/zenodo.18251405

Vahdati, S., Filice, R., & Erickson, B. (2025, October 21). *Navigating the integration of FDA cleared AI tools in clinical practice*. American College of Radiology. https://edhub.ama-assn.org/acr-lifelong-learning/module/2840533

Thank you

Ready for what's next?

Let's talk

Horizon Valley Health System